Ficha de Trabalho — Autenticação e Autorização em API REST

Disciplina: Programação Web

Tema: Autenticação com JWT e proteção de rotas

Tecnologias: Node.js, Express, Prisma, JWT, bcrypt

Docentes:

Célia Soares (P) Email: celiasoares@estg.ipvc.pt

Marcelo Antunes Fernandes (Docente Responsável - T) Email: fernandesmarcelo@estg.ipvc.pt

1. Enquadramento

Numa API REST, a autenticação permite verificar a identidade de um utilizador, enquanto a autorização determina quais os recursos a que esse utilizador pode aceder.

Nesta ficha, vais implementar um sistema completo de autenticação utilizando:

- passwords cifradas com bcrypt

- autenticação com JWT (JSON Web Token)

- proteção de rotas através de middleware

2. Objetivos

- implementar registo e login de utilizadores

- cifrar passwords de forma segura

- gerar e validar tokens JWT

- proteger rotas numa API

- testar endpoints com autenticação

3. Pré-requisitos

- projeto Node.js com Express

- Prisma configurado

- base de dados funcional

- rotas CRUD já implementadas

4. Enunciado

Deves evoluir a API existente, adicionando um sistema de autenticação e autorização.

A aplicação deverá permitir:

1. registar utilizadores

2. autenticar utilizadores

3. gerar tokens JWT

4. validar tokens em pedidos

5. proteger rotas da API

5. Desenvolvimento

Parte A — Preparação

Instalar dependências:

npm install jsonwebtoken bcrypt

Adicionar ao .env:

JWT_SECRET="uma_chave_secreta"

Parte B — Modelo de dados

Criar modelo User com:

id, name, email (único), password, createdAt, updatedAt

Atualizar base de dados e gerar Prisma Client

Parte C — Registo

POST /auth/signup

- validar dados

- verificar email existente

- cifrar password com bcrypt.hash()

- guardar utilizador

- devolver dados sem password

Parte D — Login

POST /auth/signin

- validar dados

- verificar utilizador

- comparar password com bcrypt.compare()

- gerar token com jwt.sign()

- devolver token

Parte E — Middleware

Criar authenticateToken:

- ler header Authorization

- extrair Bearer token

- validar com jwt.verify()

- guardar em req.user

Parte F — Rotas protegidas

Aplicar middleware às rotas de tasks

Parte G — Testes

Testar:

- signup

- signin

- rotas sem token

- rotas com token inválido

- rotas com token válido

6. Desafios

- GET /auth/profile

- Associação utilizador/tarefas

- Roles (admin/user)

7. Entrega

- projeto completo

- schema.prisma

- coleção Postman

- screenshots

Criar um repositório no GitHub (ou noutra plataforma equivalente);

Fazer upload de todo o projeto;

Garantir que o repositório contém:

- todo o código-fonte da aplicação;
- ficheiro schema.prisma;
- ficheiro package.json;
- instruções de instalação no README.md;

Realizar commits ao longo do desenvolvimento (não apenas um commit final);

Partilhar o link do repositório.

8. Organização sugerida

1. Registo

2. Login

3. Middleware

4. Rotas protegidas

Dica: testa cada passo antes de avançar.